

Executive Decision Brief: Backup Modernization and Ransomware Resilience

To: Meridian Advisory Group Executive Leadership

From: Cybersecurity Leadership Team

Subject: Approval of Backup Modernization Initiative

Date: [Insert date]

1. Decision Required

Executive leadership should approve the proposed **\$200,000 backup modernization initiative** this fiscal year. The initiative should include upgraded backup infrastructure, protected copies of critical data, documented recovery procedures, and regular restoration testing.

2. Organizational Context

Meridian Advisory Group depends on its systems and information to provide consulting and compliance services to financial, healthcare, and federal contracting clients. The company stores client financial information, protected health information (PHI), federal contract data, and employee records across a mixture of cloud services and on-premises systems.

Meridian's backups were last tested 14 months ago. Its cyber-insurance policy is also due for renewal in four months, and the insurer has specifically asked about backup-testing frequency. These facts make backup modernization an immediate business and governance issue rather than only an IT concern.

3. Risk

Meridian cannot currently demonstrate that it could reliably restore its systems after ransomware, hardware failure, accidental deletion, or another major disruption. Backups may exist, but their availability, completeness, and integrity have not recently been verified.

If the backups fail, Meridian could lose access to client information and important business systems for an extended period. Consequences could include interrupted client services, lost revenue, emergency recovery expenses, contractual disputes, regulatory scrutiny, and reputational damage.

There is uncertainty about the condition of the current backups because no recent restoration test has been performed. It is possible that they would work, but relying on that assumption would leave Meridian accepting a major operational risk without supporting evidence. CISA

recommends maintaining offline, encrypted backups and regularly testing their availability and integrity because ransomware can attempt to encrypt or delete accessible backups.

4. Stakeholders

The most important stakeholders are:

- **Executive leadership and the board:** Accountable for business continuity, financial risk, and formal acceptance of significant remaining risks.
- **Clients:** Depend on Meridian to protect their information and continue providing contracted services.
- **Employees:** Need access to email, documents, applications, and other systems to perform their jobs.
- **IT and cybersecurity personnel:** Will implement, maintain, document, and test the backup environment.
- **Legal, privacy, and compliance personnel:** Must evaluate regulatory, contractual, breach-notification, and data-handling requirements.
- **Finance and insurance personnel:** Must manage the investment and provide accurate information during the cyber-insurance renewal.
- **Regulators and contracting partners:** May require evidence that sensitive information is protected and that Meridian can continue or restore essential operations.

5. Current Controls

Meridian currently maintains backups, but the available information does not show whether they are isolated from production systems, protected against alteration, or capable of restoring critical operations within an acceptable period. The last backup test occurred 14 months ago.

These controls are **partially sufficient** because maintaining backups provides some protection, but untested backups do not establish a dependable recovery capability. Meridian also lacks a written incident-response plan, which could make restoration decisions slower and less coordinated during an emergency.

6. Options

Option	Benefits	Risks and limitations	Cost and operational impact
1. Approve full modernization	Provides upgraded backup capabilities, documented procedures, protected	Implementation will require staff time, planning, vendor support, and testing.	\$200,000, plus ongoing administration and testing.

Option	Benefits	Risks and limitations	Cost and operational impact
	backup copies, and regular restoration testing. It also supports the insurance renewal and improves client confidence.	Some systems may need brief maintenance periods.	
2. Approve a limited short-term project	Allows Meridian to test current backups, correct urgent failures, and improve protection for its most critical systems.	Aging or inadequate infrastructure may remain. Less critical systems may not receive the same protection, and another request for funding may be required later.	Less than the full initiative, but the amount would require a defined scope and vendor estimate.
3. Retain the current system and accept the risk	Preserves the \$200,000 for other security priorities and avoids immediate implementation demands.	Meridian would remain unable to demonstrate reliable recovery. Insurance, contractual, operational, and client risks would continue.	No immediate project cost, but potentially substantial recovery and downtime costs if an incident occurs.

All three options are possible. However, the third option should only be selected if executive leadership formally accepts the remaining risk after reviewing its possible operational and insurance consequences.

7. Legal, Privacy, Compliance, and AI Considerations

Because Meridian handles PHI as a business associate, its backup and recovery practices may be subject to the HIPAA Security Rule. HHS states that regulated entities must establish procedures for emergencies affecting systems containing electronic PHI, including plans for data backup, recovery of lost data, and continuation of critical business processes.

Meridian must also examine its client contracts, business associate agreements, federal contracting requirements, and applicable state privacy laws. These requirements may affect backup retention, encryption, storage location, access, destruction, and incident notification.

If an outside backup provider is selected, legal and privacy personnel should review its security practices, subcontractors, data locations, breach-notification terms, deletion procedures, and

right-to-audit provisions. Meridian should confirm that the provider is permitted to store each category of client data.

AI is not central to this decision. If a proposed backup product uses AI to classify information, recommend recovery actions, or automate containment, Meridian should determine what data the system processes and require human approval for actions that could delete, isolate, or overwrite business information.

The insurance application must be answered accurately. Legal counsel or an insurance specialist should review questions that could affect coverage. Leadership should not assume that modernization guarantees coverage or a lower premium because the final decision belongs to the insurer.

8. Governance and Accountability

- **Risk owner:** The Chief Information Officer should own the operational availability risk, working with the CISO on cybersecurity risk.
- **Decision approval:** Executive leadership should approve the investment. The board or board risk committee should receive notice because the decision affects organizational resilience and insurance risk.
- **Implementation:** IT infrastructure personnel should implement the system with cybersecurity oversight and qualified vendor support.
- **Legal and compliance review:** Legal, privacy, and compliance personnel should review contracts, data-handling requirements, and regulatory obligations.
- **Oversight:** The CISO should report testing results, unresolved weaknesses, and recovery-readiness measurements to executive leadership.

A successful installation should not be treated as project completion. Accountability must include evidence that selected systems can actually be restored.

9. Recommendation

I recommend that Meridian **approve the full \$200,000 backup modernization initiative before the cyber-insurance renewal.**

This option provides the strongest balance of risk reduction, operational continuity, regulatory responsibility, and cost. Meridian serves clients that depend on the confidentiality and availability of sensitive information. The company should not rely on backups that have gone untested for 14 months.

The recommendation is also consistent with the NIST Cybersecurity Framework 2.0, which treats **Govern, Identify, Protect, Detect, Respond, and Recover** as connected parts of cybersecurity risk management. The investment will not prevent every ransomware attack, but it

can reduce the length and severity of an interruption by giving Meridian a verified method of restoring essential services.

10. Cost and Resource Considerations

The initiative requires the provided **\$200,000 investment**. Additional resource requirements include:

- IT and cybersecurity staff time;
- procurement and contract review;
- identification of critical systems and information;
- vendor evaluation and implementation support;
- possible maintenance periods;
- documentation of backup and recovery procedures;
- employee training for personnel responsible for recovery; and
- recurring restoration tests and reporting.

Before implementation, Meridian should establish recovery priorities. Leadership and system owners should define how quickly each critical service must be restored and how much recent data loss the organization could tolerate. Exact recovery targets should be based on a business-impact analysis rather than invented during procurement.

11. What Happens If We Do Nothing?

If leadership does not approve the initiative, Meridian will continue operating without recent evidence that its backups can restore critical systems. The backups might function, but their reliability would remain uncertain until tested.

Meridian would also enter its insurance renewal with an acknowledged 14-month testing gap. The insurer could impose additional requirements or change the policy's price, limits, deductible, or renewal decision. The exact insurance effect cannot be predicted without reviewing the policy and the insurer's underwriting decision.

Accepting the risk would not guarantee that an incident occurs. It would mean that leadership knowingly accepts greater uncertainty, potentially longer downtime, and higher recovery costs if one does occur.

12. Immediate Actions

If leadership approves the recommendation, Meridian should:

1. Assign the CIO as risk owner and name an implementation project manager.

2. Inventory systems and identify the information and services that are most important to operations.
3. Conduct a business-impact analysis and establish recovery priorities and testing criteria.
4. Test the current backups immediately to identify urgent failures.
5. Evaluate backup solutions that provide encrypted and isolated or immutable copies.
6. Complete legal, privacy, contractual, and vendor-risk reviews before signing an agreement.
7. Develop a phased implementation plan that limits service interruptions.
8. Conduct documented restoration tests before declaring the project complete.
9. Establish recurring tests, with results reported to the CISO and executive leadership.
10. Provide accurate, documented backup information during the insurance renewal.

13. Decision Triggers

Leadership should reconsider or accelerate the decision if:

- a restoration test fails or shows that critical services cannot be recovered;
- ransomware, destructive malware, or confirmed unauthorized access affects Meridian or a major vendor;
- the insurer requires more frequent testing or protected backups as a condition of renewal;
- a client contract or regulatory requirement introduces stronger recovery obligations;
- the selected vendor experiences a breach or material service failure;
- implementation cost or timing changes enough to prevent the project from meeting its goals;
- or
- Meridian introduces a major new cloud service, client portal, or category of regulated information.

AI Evaluation

I used ChatGPT Edu as a skeptical executive reviewer after preparing the initial brief.

One weakness the AI review correctly identified was that the first draft recommended modernization without clearly defining how Meridian would determine whether recovery was successful. I agreed that purchasing backup technology alone would not prove that the organization could resume operations.

The AI also suggested including exact recovery times for Meridian's critical systems. I modified this recommendation because the scenario does not provide a business-impact analysis or enough operational information to support precise recovery targets. Inventing those targets would create unsupported information. Instead, I added an immediate action requiring leadership and system owners to establish recovery priorities and approved recovery objectives.

After the review, I improved the brief by making documented restoration testing a condition for project completion. I also added ongoing reporting responsibilities so executive leadership receives evidence of recovery readiness rather than only confirmation that a backup product was installed.

References

Cybersecurity and Infrastructure Security Agency. (n.d.). *#StopRansomware* guide. <https://www.cisa.gov/stopransomware/ransomware-guide>

National Institute of Standards and Technology. (2024). *The NIST Cybersecurity Framework (CSF) 2.0*. <https://www.nist.gov/publications/nist-cybersecurity-framework-csf-20>

U.S. Department of Health and Human Services. (n.d.). *Summary of the HIPAA Security Rule*. <https://www.hhs.gov/hipaa/for-professionals/security/laws-regulations/index.html>

AI Use Disclosure: ChatGPT Edu was used to help organize, draft, and review this executive decision brief. The author reviewed and approved the final content.